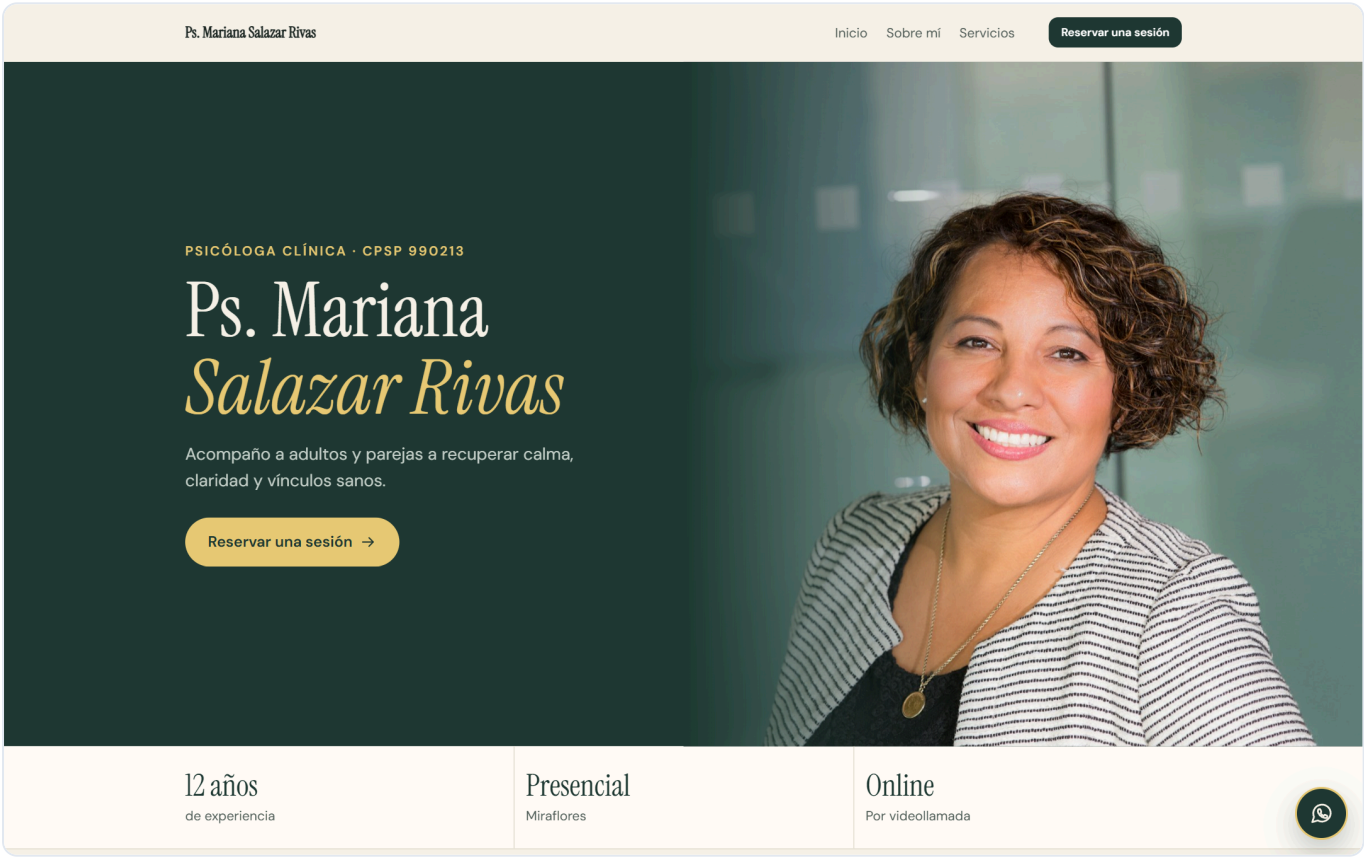
CASO DE ESTUDIO · SAAS DE SALUD · 2026

Agenda, pacientes y cobros para psicólogos independientes

SaaS multi-consultorio: cada psicóloga tiene su página pública editable, sus pacientes reservan sin crear cuenta y ella gestiona agenda, pacientes, pagos y reportes desde el celular. Diseñado con privacidad estricta para datos de salud mental.

Next.js 16 · React 19 · TypeScript · PostgreSQL 17 · Supabase autoalojado · Row Level Security · Docker · Playwright



AUTOR
Bryan Jeremy Espinoza Herrera
BJOTA Systems · Perú

ESTADO
Listo en ensayo de producción
despliegue en VPS pendiente

DESARROLLO
Ago. – oct. 2026
177 commits

01 Resumen

Las psicólogas independientes gestionan su consulta con WhatsApp, cuadernos y memoria: los comprobantes llegan por chat, las reprogramaciones se conversan y no hay un registro claro de quién debe qué. Construí un **SaaS multi-consultorio** donde cada profesional tiene una página pública propia, recibe solicitudes de cita que confirma con un toque y lleva agenda, pacientes, cobros y reportes en un solo lugar. Por tratarse de datos de salud mental, la privacidad y el aislamiento entre consultorios fueron requisitos desde el primer día.

3116
pruebas Vitest (unitarias e integración)

436
pruebas E2E con Playwright en 58 specs

87
migraciones con RLS y políticas

21/21
pruebas adversariales de privilegios

02 El problema

Citas por WhatsApp

Responder "¿tienes horario?" entre sesiones; reprogramaciones que se pierden en el chat.

Cobros sin control

Comprobantes de transferencia sueltos y sesiones atendidas que nadie recuerda si se pagaron.

Sin presencia profesional

Muchas psicólogas no tienen una página donde mostrar enfoque, formación y precios.

Datos sensibles mal guardados

Información de pacientes en cuadernos y conversaciones sin ninguna protección.

03 La solución

Página profesional

Perfil con enfoque, temas, servicios, formación, ubicación y preguntas frecuentes, editable por bloques.

Reserva sin cuenta

El paciente elige servicio, día y hora; la profesional confirma o rechaza la solicitud.

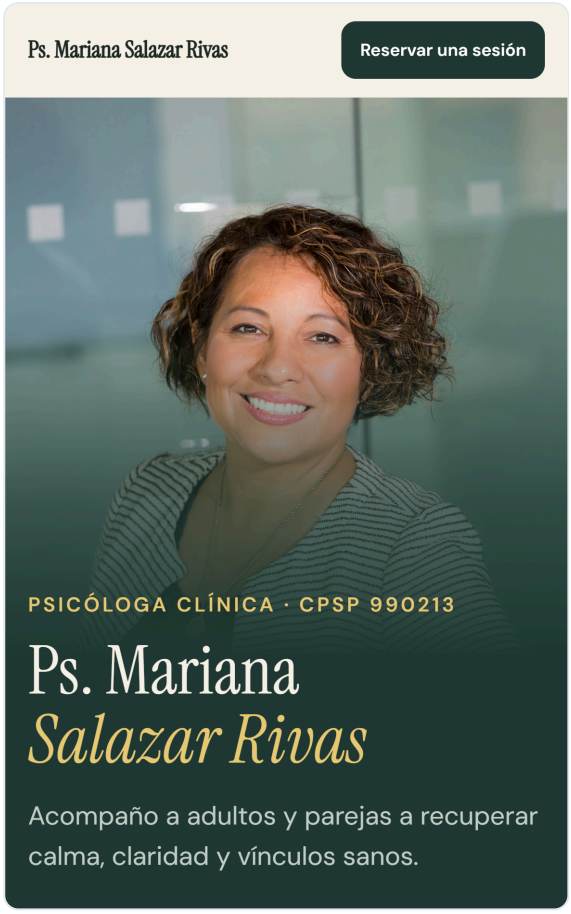
Consulta ordenada

Agenda del día y de la semana, pacientes, cobros con comprobante, mensajes de WhatsApp listos y reportes.

04 La página pública de la profesional



Página del perfil de demostración «Ps. Mariana Salazar Rivas» (persona ficticia).

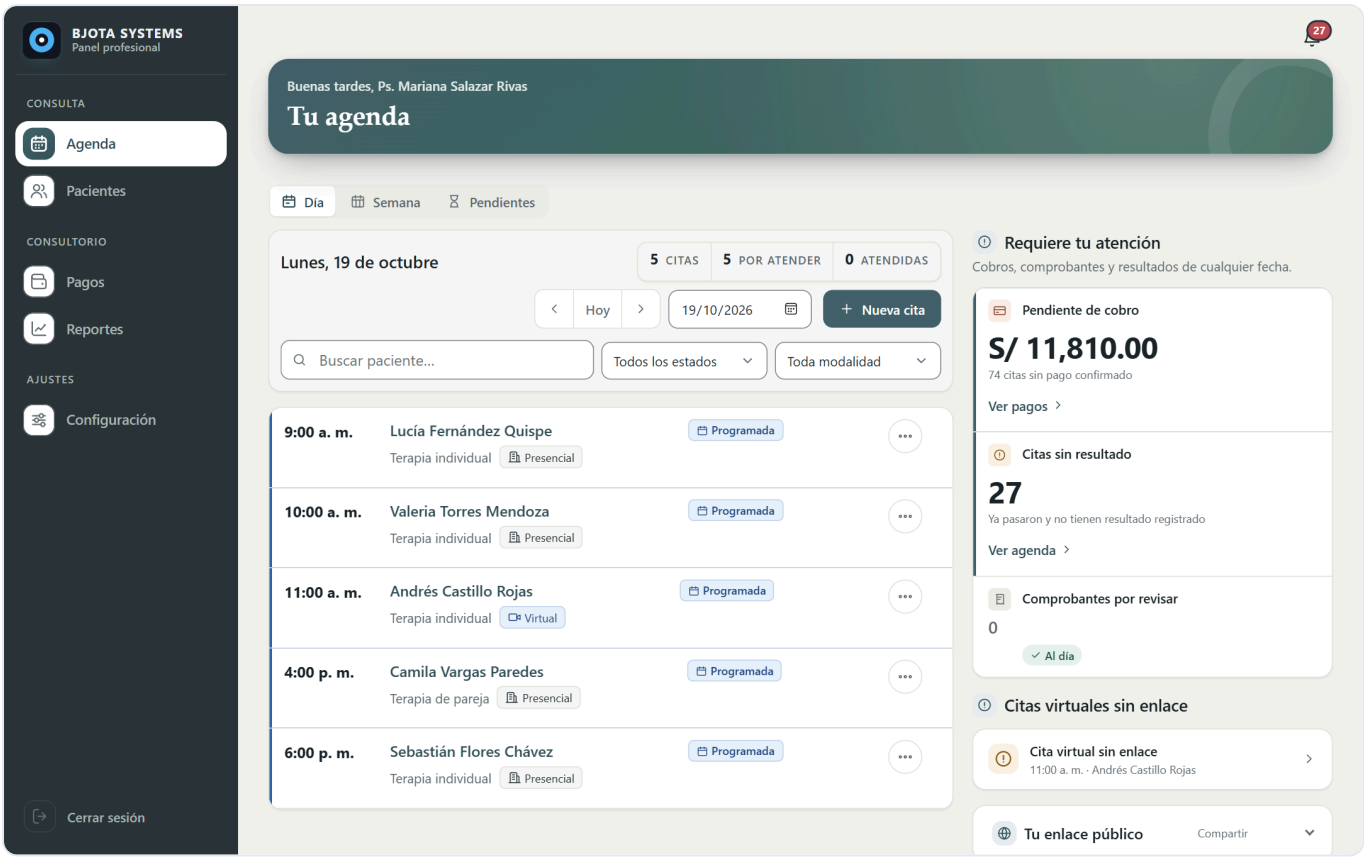


Vista en el celular.

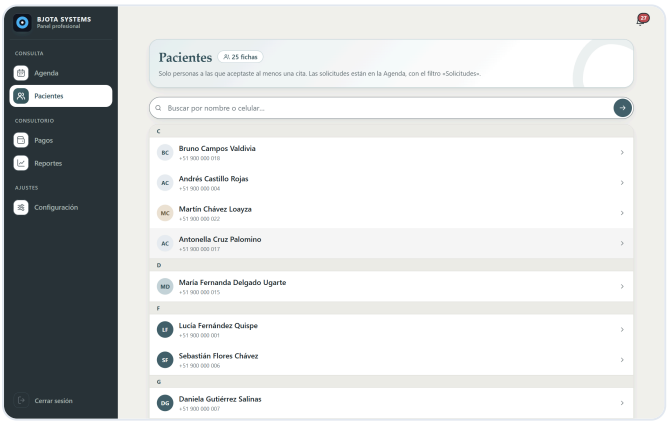


Reserva en 4 pasos, sin crear cuenta.

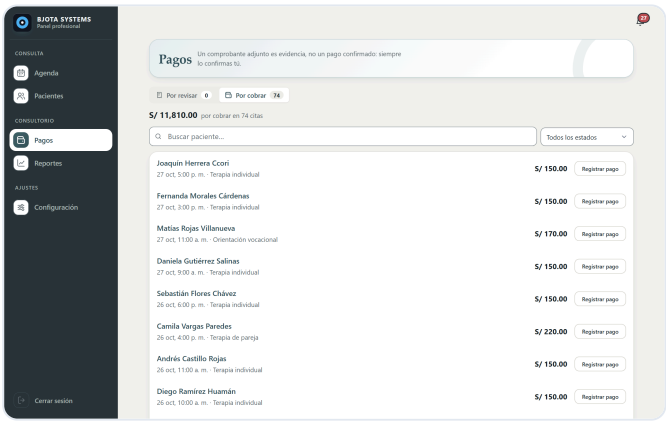
05 El panel de la psicóloga



Agenda del día, con lo que requiere atención: cobros pendientes, citas sin resultado y comprobantes por revisar.

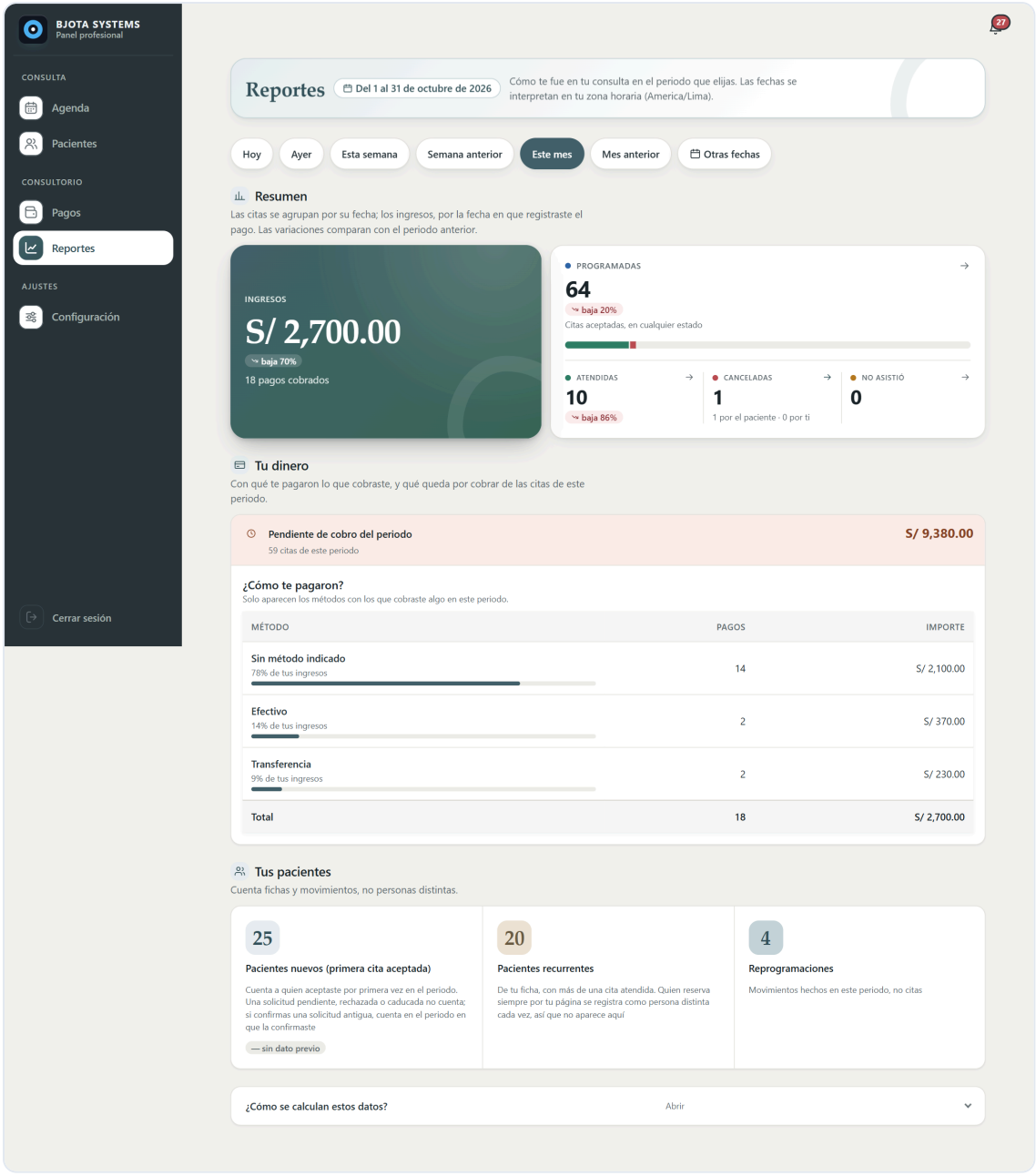


Pacientes: solo datos administrativos, sin historia clínica (minimización deliberada).

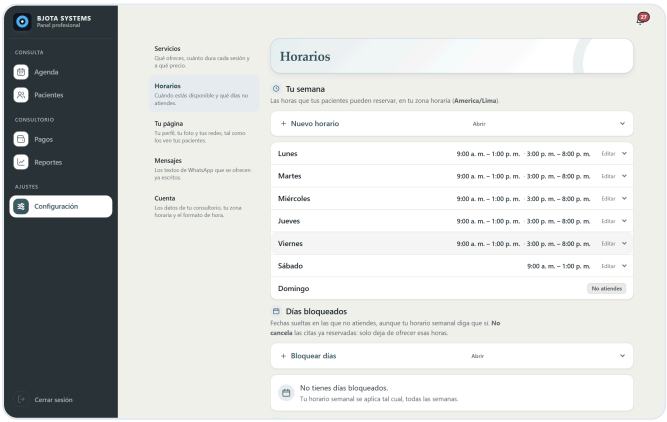


Pagos por cobrar y comprobantes por revisar.

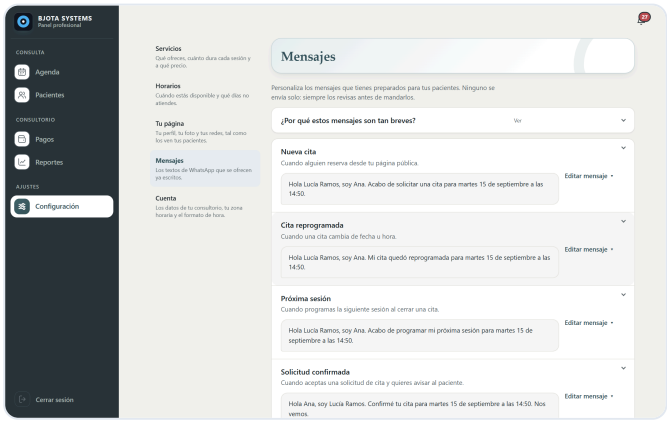
06 Reportes y configuración



Reportes del mes: ingresos, citas programadas y atendidas, inasistencias y cobros por método.

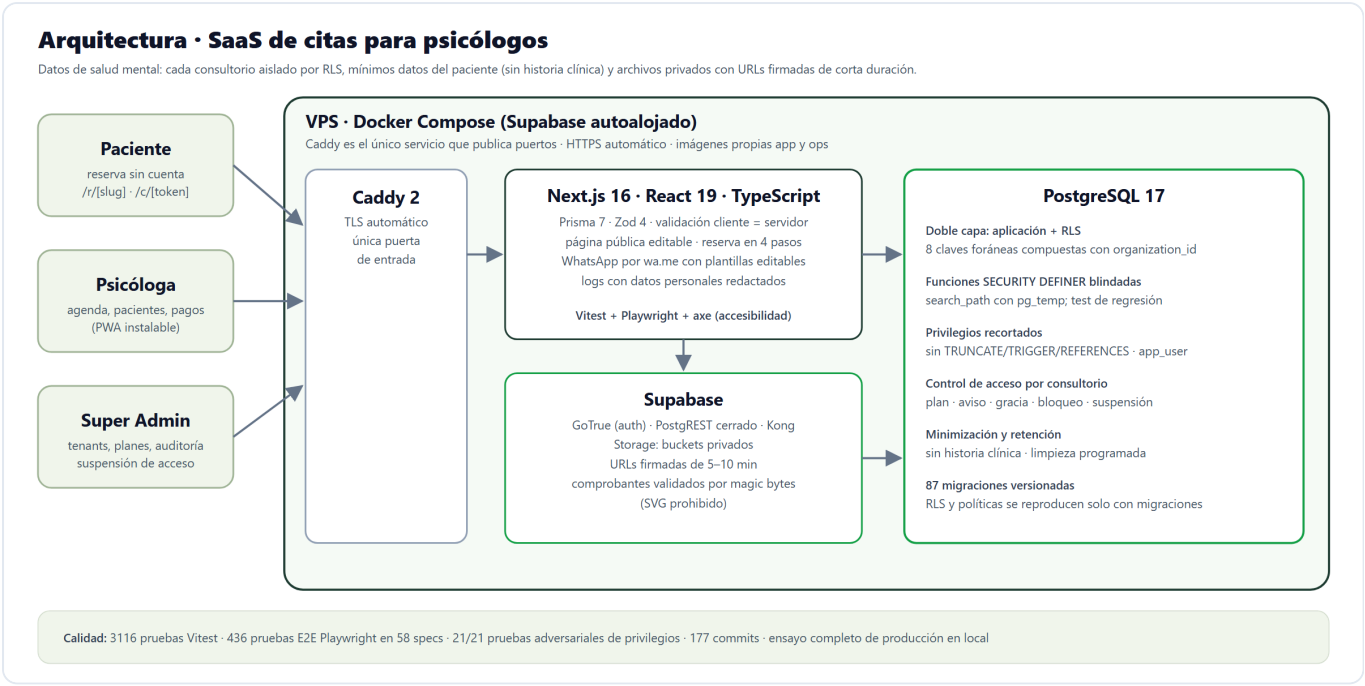


Horario semanal con pausas y días bloqueados.



Plantillas de WhatsApp editables (se envían desde su propio número).

07 Arquitectura



Decisiones clave

Decisión	Por qué
Aislamiento en dos capas	La aplicación filtra por consultorio y, además, PostgreSQL lo exige con RLS y 8 claves foráneas compuestas con `organization_id`. Verificado con 17 pruebas contra una base real.
Minimización de datos	No se guarda historia clínica, notas ni diagnósticos: solo lo necesario para agendar y cobrar. Lo que no se guarda no se puede filtrar.
Solicitud, no reserva automática	La cita del paciente entra como solicitud que la profesional confirma, para cuidar su agenda y evitar abusos.
Archivos privados	Comprobantes en buckets privados, validados por su firma binaria (sin SVG) y servidos con URLs firmadas de 5 a 10 minutos.
Supabase autoalojado	Todo el stack (Postgres, Auth, Storage, Kong y la app) en Docker Compose detrás de Caddy, el único servicio expuesto, para que los datos queden bajo control propio.
Acceso por consultorio	Planes con aviso, periodo de gracia, bloqueo y suspensión aplicados por la base de datos, no solo por la interfaz.

08 Seguridad: un fallo real encontrado y corregido

Hallazgo: durante la revisión de seguridad descubrí que una función `SECURITY DEFINER` sin `pg_temp` en su `search_path` permitía saltarse RLS y escalar a Super Admin. Se corrigió y ahora una prueba de regresión falla si cualquier función queda sin esa protección.

- **Privilegios recortados:** se revocaron `TRUNCATE`, `TRIGGER`, `REFERENCES` y `MAINTAIN`; 21/21 pruebas adversariales en verde. La app usa un rol `app_user` y PostgREST queda cerrado.
- **Logs sin datos personales:** redacción de datos personales y secretos, con 33 pruebas.
- **Enlaces de un solo uso:** las propuestas de reprogramación llegan al paciente como enlace que caduca en 48 h.
- **Medición, no suposición:** medí que el límite de autenticación por defecto permitía unas 900 peticiones por minuto y lo dejé documentado como riesgo a reforzar.
- **Modelo de amenazas** basado en OWASP y clasificación de datos documentados; retención con limpieza programada en modo de prueba.
- **Accesibilidad:** pruebas automáticas con axe-core en las pantallas principales.

09 Estado del proyecto

- **Funcional y probado:** todo el MVP corre en un **ensayo completo de producción en local** (los mismos contenedores que irán al VPS, con HTTPS) y pasa sus verificaciones (26/26 de mantenimiento).
- **Siguiente paso:** despliegue en el VPS, dominio y DNS, certificados reales, correo transaccional y la política de backups antes de recibir datos reales.
- **Fuera del MVP a propósito:** pasarela de pago, recordatorios automáticos y autogestión de citas por el paciente.

10 Lo que aprendí

- **La seguridad se prueba atacando.** El fallo de escalada a Super Admin no lo habría encontrado sin pruebas adversariales; ahora es parte de la suite.
- **Con datos de salud, menos es más.** Decidir qué no guardar fue tan importante como decidir qué construir.
- **Ensayar antes de desplegar.** Levantar el stack completo de producción en local, con backups y restauración, reduce el riesgo del primer despliegue real.
- **Probar como el usuario.** 436 pruebas E2E con Playwright recorren los flujos reales de la psicóloga y del paciente, incluida la accesibilidad.
- **IA como herramienta con método.** Desarrollé con asistentes de IA usando un plan maestro, planes por fase y checkpoints verificados.

11 Mi rol

Proyecto propio de principio a fin: definí el producto con una psicóloga piloto, diseñé el modelo de datos, la arquitectura y la estrategia de privacidad, desarrollé la aplicación con apoyo de asistentes de IA, escribí las pruebas (unitarias, de integración, adversariales y E2E) y preparé la infraestructura autoalojada para producción.

Todas las capturas son de una copia local con la cuenta de demostración «Ps. Mariana Salazar Rivas»: persona, pacientes y teléfonos ficticios; foto de Unsplash (Christina @ wocintechchat). No se publican el código fuente, datos reales ni secretos de infraestructura.

Bryan Jeremy Espinoza Herrera · BJOTA Systems · 2026